Story 1: Authenticated Project Entry

Summary

The user can sign in, reach the platform, see only accessible projects, and sign out cleanly from authenticated project work.

Description

User Profile

- **Primary User:** A technical founder, tech lead, staff engineer, or agentic operator who wants to run high-quality crafted processes through one durable project surface instead of manually stitching together prompts, tools, documents, and environments.
- **Context:** The user is starting or resuming work inside a concrete project. They need one durable container that holds processes, artifacts, and source attachments before deeper process-specific behavior begins.
- **Mental Model:** "I have a project. Inside that project I run one or more processes. The platform should show me my projects, let me open the right one, and keep each process separate."
- **Key Constraint:** The platform must preserve durable project and process state without flattening work into a generic chat thread or treating a sandbox filesystem as the source of truth.

Objective

Give authenticated users a safe entry point into project work, show only the projects they can access, expose role context at entry points, protect direct URLs, and let the user sign out without leaving authenticated project data visible.

Scope

In Scope

- Authenticated access to project work
- Session restoration for valid sessions
- Redirect to sign in for missing or invalid sessions
- Project index filtered to accessible projects only
- Empty state when no projects are available
- Owner/member role visibility in project entry surfaces

- Access-denied or unavailable behavior for blocked direct navigation
- Sign-out action from authenticated project surfaces

Out of Scope

- Project creation submit flow
- Project shell summary rendering details
- Process creation
- Durable return/recovery behavior after project work has already been established

Dependencies

- Story 0
- Shared authenticated-shell bootstrap and route-state foundations
- Shared fixtures for owner/member/inaccessible project states

Acceptance Criteria

AC-1.1: Project work requires an authenticated session. The platform redirects unauthenticated users to sign in and restores valid sessions without forcing unnecessary re-authentication.

- **TC-1.1a: Authenticated user lands on project index**
  - Given: User has a valid session
  - When: User opens the platform root or a project-work URL
  - Then: The platform loads the user's project surface without showing a login challenge first
- **TC-1.1b: Unauthenticated user is redirected to sign in**
  - Given: User has no valid session
  - When: User opens the platform root or a project-work URL
  - Then: The platform redirects the user to the sign-in flow before showing any project data
- **TC-1.1c: Expired or invalid session**
  - Given: User has a stale or invalid session token
  - When: User opens the platform
  - Then: The platform clears the invalid session, redirects the user to sign in, and does not expose project data

AC-1.2: The project index shows only the projects the current user can access and provides a clear empty state when none are available.

- **TC-1.2a: User with accessible projects**
  - Given: User has access to three projects

    - When: The project index loads
    - Then: The index shows those three projects and no inaccessible projects
- **TC-1.2b: User with no accessible projects**
    - Given: User has no accessible projects
    - When: The project index loads
    - Then: The index shows an empty state with a create-project action
- **TC-1.2c: Hidden inaccessible project**
    - Given: Another project exists but the current user is not an owner or member
    - When: The project index loads
    - Then: That project does not appear anywhere in the project list
- **TC-1.2d: Same-name projects from different owners remain distinguishable**
    - Given: User can access two projects with the same display name but different owners
    - When: The project index loads
    - Then: Both entries appear with enough owner or summary context to distinguish them

AC-1.3: The project index and project shell show the user's role for each accessible project and block direct access to projects they cannot open.

- **TC-1.3a: Owner role shown**
    - Given: User owns a project
    - When: That project appears in the index or shell
    - Then: The UI labels the user as an owner for that project
- **TC-1.3b: Member role shown**
    - Given: User is a member but not an owner of a project
    - When: That project appears in the index or shell
    - Then: The UI labels the user as a member for that project
- **TC-1.3c: Unauthorized direct navigation**
    - Given: User is not allowed to open a project
    - When: User navigates directly to that project's URL
    - Then: The system shows a project-unavailable or access-denied state and does not leak the project's contents

AC-1.4: Authenticated project surfaces provide a sign-out action that ends the current session, returns the user to a signed-out state, and blocks access to project data until the user signs in again.

- **TC-1.4a: Sign out from project surface**
    - Given: User is authenticated and viewing the project index or project shell
    - When: User activates sign out

    - Then: The platform ends the current session and returns the user to a signed-out state
- **TC-1.4b: Signed-out user revisits prior project URL**
    - Given: User previously signed out from the platform
    - When: User revisits a bookmarked project URL
    - Then: The platform requires sign-in again before showing any project data
- **TC-1.4c: Sign out clears active shell context**
    - Given: User is viewing a project shell with project data already loaded
    - When: User signs out
    - Then: The platform does not leave the prior project's data visible as an authenticated working surface

Technical Design

Endpoints

Operation	Method	Path	Description
Get authenticated user	GET	`/auth/me`	Returns the current authenticated user or 401 if not authenticated
Sign out authenticated user	POST	`/auth/logout`	Ends the current authenticated session and returns the browser to a signed-out state
List accessible projects	GET	`/api/projects`	Returns the projects the current user can access
Get project shell data	GET	`/api/projects/{projectId}`	Returns project identity plus project shell summaries

At Story 1 boundary, the authenticated shell path must prove auth/session handling, project access gating, role visibility, and sign-out behavior. Fully populated project-shell sections remain later story work.

Shell Bootstrap Payload

Field	Type	Required	Description
actor	Authenticated User or null	yes	Current authenticated user summary for initial shell bootstrap
pathname	string	yes	Current browser pathname
search	string	yes	Current browser querystring
csrfToken	string or null	yes	CSRF token used for browser-owned POST actions such as sign out
auth.loginPath	string literal	yes	Login route for unauthenticated redirects
auth.logoutPath	string literal	yes	Logout route used by shell chrome

Authenticated User Response

Field	Type	Required	Validation	Description
user.id	string	yes	non-empty	Stable authenticated user identifier
user.email	string	no	valid email when present	User email address
user.displayName	string	no	non-empty when present	User display name for shell presentation

Sign Out Response

`POST /auth/logout` returns `200` with a logout redirect payload after the authenticated session has been invalidated successfully.

Logout Request Contract

Field	Type	Required	Description
`X-CSRF-Token` header	string	yes	Client sends the bootstrap-delivered CSRF token back on logout

Field	Type	Required	Description
request origin context	browser request metadata	yes	Logout request must come from a valid browser origin context

The CSRF token is injected into `window.__SHELL_BOOTSTRAP__` during shell delivery and read by the client when it posts to `/auth/logout`.

Project Summary Response

Field	Type	Required	Validation	Description
projectId	string	yes	non-empty	Stable project identifier
name	string	yes	non-empty	Project display name
ownerDisplayName	string	no	non-empty when present	Project owner display name for distinguishing same-name project entries
role	enum	yes	`owner` or `member`	Current user's role in the project
processCount	integer	yes	`>= 0`	Number of processes in the project
artifactCount	integer	yes	`>= 0`	Number of project artifacts
sourceAttachmentCount	integer	yes	`>= 0`	Number of source attachments
lastUpdatedAt	string	yes	ISO 8601 UTC	Most recent durable update time for the project

Sort order: Project list is sorted by `lastUpdatedAt` descending.

Project Shell Request Parameters

Parameter	Type	Required	Description
`projectId`	string	Yes	Path parameter for the project to open
`processId`	string	No	Query parameter for the currently selected process within the already-loaded shell summaries

Error Responses

Status	Code	Description
401	`UNAUTHENTICATED`	User is not authenticated
403	`PROJECT_FORBIDDEN`	User does not have access to the requested project
404	`PROJECT_NOT_FOUND`	Requested project does not exist

See the tech design document for full architecture, implementation targets, and test mapping.

Definition of Done

- [ ] Session restoration and sign-in redirect behavior satisfy TC-1.1a through TC-1.1c
- [ ] Project index shows only accessible projects and distinguishes same-name projects per TC-1.2a through TC-1.2d
- [ ] Owner/member role visibility and blocked direct navigation satisfy TC-1.3a through TC-1.3c
- [ ] Sign-out behavior invalidates the session, clears authenticated shell context, and protects bookmarked URLs per TC-1.4a through TC-1.4c
- [ ] Story tests cover authenticated, unauthenticated, stale-session, member, owner, and forbidden-access paths